

Informatique & Web

Questionnaire d'audit RGPD (vierge)

ACME - Audit 2026
37 question(s) - 26/08/2026

Questionnaire vierge : cochez pour chaque point l'état de conformité et complétez la zone de commentaire.

Gouvernance & Pilotage

Un Délégué à la Protection des Données (DPO) a-t-il été désigné ?

Art. 37

Vérifier qu'une personne (interne ou externe) est officiellement nommée DPO. Obligatoire pour les organismes publics, ceux dont l'activité de base implique un suivi régulier et systématique à grande échelle, ou le traitement à grande échelle de données sensibles. Preuve : lettre de mission ou contrat.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Si DPO désigné, ses coordonnées ont-elles été communiquées à la CNIL ?

Art. 37.7

Le DPO doit être déclaré à la CNIL via le téléservice dédié. Preuve : accusé de réception / récépissé de désignation CNIL.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Les coordonnées du DPO sont-elles publiées (site web, mentions légales) ?

Art. 37.7

Les coordonnées (email générique de préférence, ex. dpo@societe.fr) doivent être publiques : mentions légales, politique de confidentialité, page contact.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Le DPO dispose-t-il des ressources nécessaires (temps, budget, formation) ?

Art. 38

Le DPO doit disposer de temps dédié, d'un budget, d'un accès à la formation continue et aux ressources documentaires. Preuve : fiche de poste, % de temps alloué, budget formation.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Le DPO est-il associé à toutes les questions relatives à la protection des données ?

Art. 38.1

Le DPO doit être associé en amont (pas après coup) à tout nouveau projet, outil ou traitement impliquant des données personnelles. Preuve : comptes rendus de réunions projet, circuit de validation.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Une politique interne de protection des données est-elle formalisée ?

Document interne cadre décrivant les règles de protection des données de l'organisme : rôles, procédures, engagements. Preuve : politique signée par la direction, datée et versionnée.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Cette politique est-elle communiquée à l'ensemble du personnel ?

Vérifier la diffusion effective : intranet, livret d'accueil, email de communication, émargement. La simple existence du document ne suffit pas.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Un comité ou référent RGPD est-il en place dans chaque service métier ?

Des relais RGPD identifiés dans chaque direction (RH, marketing, IT, achats) facilitent la remontée d'information. Preuve : liste nominative des relais, comptes rendus de comité.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Un budget annuel est-il alloué à la conformité RGPD ?

Un budget identifié (outillage, formation, conseil, audits, sécurité) montre l'engagement réel. Preuve : ligne budgétaire annuelle.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

La direction est-elle régulièrement informée du niveau de conformité ?

Un reporting périodique (tableau de bord, rapport annuel du DPO) doit remonter au COMEX/direction. Preuve : rapport annuel, slides de comité de direction.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Une cartographie des traitements est-elle tenue à jour ?

Art. 30

Vue d'ensemble des traitements, outils, flux et acteurs. Complémentaire au registre : elle sert à identifier les zones de risque. Preuve : cartographie datée et mise à jour.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Un plan d'audit interne RGPD est-il défini et exécuté ?

Programme de contrôles internes planifiés (par thème ou par direction) avec suivi des écarts. Preuve : plan d'audit, rapports de contrôle.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Existe-t-il un représentant en UE si l'organisme est hors UE ?

Art. 27

Un organisme établi hors UE qui cible des personnes en UE doit désigner un représentant dans l'Union. Preuve : mandat écrit du représentant.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Registre des traitements (Art. 30)

Un registre des traitements responsable est-il tenu ?

Art. 30.1

Registre des activités menées en tant que responsable de traitement. Obligatoire dès 250 salariés, et en pratique quasiment toujours (données sensibles, traitements non occasionnels). Preuve : fichier registre à jour.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Un registre des traitements sous-traitant est-il tenu (le cas échéant) ?

Art. 30.2

Si l'organisme traite des données pour le compte de clients (hébergeur, agence, prestataire IT), il doit tenir un second registre côté sous-traitant.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Le registre identifie-t-il le responsable de traitement et son DPO ?

Le registre doit mentionner l'identité et les coordonnées du responsable de traitement, de son représentant éventuel et du DPO.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

La finalité de chaque traitement est-elle clairement définie ?

Chaque traitement doit avoir une finalité explicite et compréhensible (ex. « gestion de la paie »), pas un intitulé vague type « données clients ».

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Les catégories de personnes concernées sont-elles identifiées ?

Qui sont les personnes dont on traite les données : clients, prospects, salariés, candidats, visiteurs, fournisseurs, mineurs...

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Les catégories de données traitées sont-elles listées ?

Lister les types de données : identité, coordonnées, vie professionnelle, données bancaires, données de connexion, données sensibles...

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

La base légale est-elle précisée pour chaque traitement ?

Art. 6

Une des 6 bases : consentement, contrat, obligation légale, intérêt vital, mission d'intérêt public, intérêt légitime. Elle doit être choisie et justifiée, pas cochée par défaut.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Les destinataires (internes/externes) sont-ils listés ?

Services internes habilités et destinataires externes (prestataires, organismes sociaux, administrations, partenaires).

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Les durées de conservation sont-elles définies et justifiées ?

Durée en base active, puis archivage intermédiaire, puis suppression. Chaque durée doit être justifiée (durée légale, besoin métier, référentiel CNIL).

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Les transferts hors UE sont-ils documentés avec garanties associées ?

Indiquer pays de destination, outil concerné et garantie utilisée (adéquation, CCT, BCR).

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Une description générale des mesures de sécurité est-elle présente ?

Résumé des mesures techniques et organisationnelles : chiffrement, contrôle d'accès, sauvegardes, habilitations.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Le registre est-il revu et mis à jour au moins annuellement ?

Le registre est un document vivant : vérifier la date de dernière mise à jour et l'existence d'une revue planifiée.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Le registre traite-t-il aussi les données RH (paie, recrutement, formation) ?

Vérifier la présence des traitements RH : paie, recrutement, formation, entretiens, gestion des absences, badgeuse.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Le registre traite-t-il les données clients/prospects ?

Vérifier la présence des traitements commerciaux : CRM, prospection, facturation, SAV, fidélité, avis clients.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Le registre traite-t-il la vidéosurveillance / contrôle d'accès ?

Vérifier la présence des dispositifs de vidéoprotection, contrôle d'accès par badge et systèmes d'alarme.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Bases légales & Consentement

Chaque traitement repose-t-il sur une base légale identifiée ?

Art. 6

Pour chaque traitement du registre, une base légale doit être identifiée et cohérente avec la finalité. Un traitement sans base légale est illicite.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Quand le consentement est utilisé, est-il libre, spécifique, éclairé et univoque ?

Art. 7

Consentement valable = choix réel (pas de conséquence négative en cas de refus), par finalité, avec information préalable claire et action explicite.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Le consentement est-il recueilli par un acte positif clair (case non pré-cochée) ?

Pas de case pré-cochée, pas de consentement déduit du silence, du défilement ou de la poursuite de navigation.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Existe-t-il une preuve traçable du consentement (date, version, IP) ?

Il faut pouvoir prouver qui a consenti, quand, à quoi et selon quelle version du texte. Preuve : journal de consentement, horodatage, version du formulaire.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Le retrait du consentement est-il aussi simple que son recueil ?

[Art. 7.3](#)

Un lien ou bouton de retrait doit être aussi accessible que le recueil (ex. désinscription en un clic, gestion des préférences).

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Pour les mineurs <15 ans, le consentement parental est-il vérifié ?

[Art. 8](#)

En France, en dessous de 15 ans, le consentement du titulaire de l'autorité parentale est requis pour les services en ligne. Vérifier le mécanisme de contrôle d'âge.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

L'intérêt légitime fait-il l'objet d'un test de mise en balance documenté ?

L'intérêt légitime nécessite un test en 3 étapes documenté : finalité légitime, nécessité, mise en balance avec les droits des personnes (LIA).

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Les conditions générales sont-elles distinctes du consentement marketing ?

L'acceptation des CGV/CGU ne doit pas valoir consentement marketing : cases distinctes et indépendantes.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :

Le consentement est-il granulaire (par finalité) ?

Un consentement par finalité (newsletter, partenaires, profilage) et non un consentement global unique.

☐ Conforme ☐ Partiellement conforme ☐ Non conforme ☐ Non applicable ☐ À évaluer

Commentaire / éléments de preuve :
